Fedlify: Bounded Agentic Assistance for Multi-Institutional Health AI Development

Omid Jafarinezhad[1], Mohammad Noaeen[1], Aviv Shachak[1,2], Behrouz Far[3], and Zahra Shakeri[1,2,4,*]

[1]Institute of Health Policy, Management and Evaluation, Dalla Lana School of Public Health, University of Toronto, Toronto, Canada
[2]Faculty of Information, University of Toronto, Toronto, Canada
[3]Department of Electrical and Software Engineering, University of Calgary, Calgary, Canada
[4]Schwartz Reisman Institute, University of Toronto, Toronto, Canada

[*]Corresponding author: zahra.shakeri@utoronto.ca

Working draft. This document assembles the Introduction, Results through the first three design subsections, Discussion, and Methods, with the figures and tables in place. Passages marked **[like this]** are gaps that require information from the implementation or a decision that has not yet been made. They are deliberately visible rather than smoothed over.

1 Introduction

A persistent challenge in health AI is the "valley of death" between developing a technically promising model and establishing its safe, effective and sustainable use in routine clinical care.[1, 2, 3] A recent deployment at Mass General Brigham illustrates this translational gap, with less than 20% of the effort devoted to prompt engineering and model development and more than 80% to data integration, validation, economic value, drift management, and governance.[2] Bridging this gap requires a sociotechnical approach that considers clinical workflows, organizational structures, governance, human factors, and technical infrastructure alongside algorithmic performance.[4, 5] One of the first challenges in crossing this valley is limited generalizability, which often arises when development data do not adequately represent the target population or the clinical setting.

Performance at the development site does not establish performance elsewhere. For example, COVID-19 screening models trained at Oxford University Hospitals achieved AUROCs of 0.757–0.817 across four UK cohorts, but only 0.577 and 0.515 at two Vietnamese hospitals, which were close to random discrimination.[6] One source of this failure is shortcut learning, in which models rely on hidden data-acquisition cues rather than clinically meaningful patterns. Across 13 clinical datasets and five modalities, these shortcuts caused internal evaluations to overestimate external performance by 20% on average.[7] Underrepresentation compounds this problem because models can become less robust and less fair when patient groups, conditions, or acquisition settings encountered during deployment were poorly represented during development.[8]

Institutional diversity can substantially improve model performance and generalizability, but its practical realization is still challenging. Recent large-scale health AI collaborations quantify these improvements. A glioblastoma model trained on 25,256 MRI scans from 6,314 patients at 71 institutions on 6 continents improved delineation of the surgically targetable tumour by 33% and the complete tumour extent by 23% compared with a model trained on public data.[9] A COVID-19 model trained across 20 institutions achieved an average AUC above 0.92, 16% higher than single-site models, with 38% better generalizability.[10] A paediatric brain tumour model developed across 19 international sites similarly improved segmentation by 20–30% at three external hospitals while performing close to centralized training.[11] However, in practice, such collaboration is constrained by privacy regulations, governance requirements, and institutional barriers surrounding the sharing of sensitive health data. These challenges are further amplified in countries with decentralized healthcare governance, such as Canada, Germany, and Australia, where jurisdiction-specific regulatory frameworks and fragmented

data infrastructures add layers of complexity.[12, 13] As a result, many health AI models are trained on single-institution datasets, which constrains their generalizability and clinical reliability across diverse patient populations.[14, 15, 16, 17]

The need for institutional diversity does not imply that health data must be centralized. Transfer learning adapts a model sequentially by using local data to refine a model trained elsewhere, as when the Oxford COVID-19 models were fine-tuned on Vietnamese data.[6] Federated learning (FL) instead enables institutions to train collaboratively and build a shared model without transferring raw patient data.[18, 19] Federated transfer learning combines both principles. However, moving from a technical demonstration to a practical multi-institutional study is difficult. All participating sites must align their data formats, labels, preprocessing steps, software environments, and approval procedures.[9, 20] They must also agree on responsibilities, model ownership, privacy safeguards, monitoring, and site withdrawal.[21, 22] These requirements often produce custom workflows that demand substantial technical expertise and are difficult to reproduce. Only 5.2% of 612 healthcare FL studies involved real-world applications,[23] and among 3,100 patient-level AI studies published between 2018 and 2025, only 5% of multicenter studies employed these methods.[24] Closing this gap requires tools that make multi-institutional studies easier to configure, coordinate, and reproduce.[9, 25, 26]

Agentic AI is one candidate for such tools, and what suits it to this work also makes it hazardous near patient data. Agentic systems combine generative models with capabilities such as planning, memory, reflection, and tool use to pursue multi-step goals and act on intermediate results.[27, 28] In rare disease diagnosis, DeepRare used more than 40 specialized tools to assess 6,401 clinical cases across 2,919 diseases, achieved 57.18% Recall@1 on phenotype-based tasks, and experts agreed with 95.4% of its reasoning chains.[29] A multi-agent assistant in Singapore's national preventive care programme generated personalised health plans that 20 residents and 7 clinicians rated significantly above neutral for appropriateness, usefulness, actionability, and personalisation.[30] Agents have also been applied to FL system design, code generation, and federated analytics.[31, 32, 33] Planning, decomposition, and tool use map onto the preparatory work that precedes any federated run, including translating an approved protocol into site-level tasks, generating readiness checklists and draft run configurations, flagging incomplete or inconsistent metadata, and recording decisions and handoffs for audit. None of this work requires access to patient records. However, placing agents near data sources or execution environments increases the consequences of reasoning errors, unsafe tool use, information exposure, and unclear accountability. A recent OpenAI–Hugging Face evaluation showed agents escaping a restricted environment, gaining internet access, chaining vulnerabilities, and exfiltrating secret data to complete a benchmark task.[34] Across 1,926 autonomous clinical-agent runs, MedCTA found frequent protocol violations, premature stopping, and incorrect tool use, which shows that agents may depart from intended workflows when their instructions, tools, and control settings do not enforce strict constraints.[35] These risks become more serious when agents interact with patient data. Therefore, the central question is not only what agents can do, but where their autonomy can be safely bounded.

This boundary lies between preparing a study and executing it. Existing FL frameworks primarily support model training and technical orchestration, whereas the operational work required to plan and coordinate a multi-institutional study is fragmented and largely manual.[22, 23, 26, 36] Limited guidance exists on how to constrain agentic assistance in privacy-sensitive, multi-institutional health AI settings. We derive 29 operational requirements spanning the lifecycle of a multi-institutional health AI study, assess 14 FL frameworks against them, and use the resulting gap to design and implement Fedlify, a bounded agentic system that preserves institutional control, human accountability, and separation from patient data and federated execution. **[The Introduction currently also promises an evaluation against an adversarial suite and a demonstration on a federated ICU readmission study across six eICU hospitals. Neither appears in the Results below. Either the promise comes out, or those sections are written.]**

2 Results

The account below moves from problem to boundary to mechanism. We first report the operational requirement set, then the framework comparison that locates where support is missing, and then the design of Fedlify in three steps: where the system sits relative to institutions and the runtime, what governs action inside it, and what happens to a single unit of work over time.

2.1 Most of a federated study happens outside the training loop

A multi-institutional health AI study begins before training and continues after a model is produced. We consolidated recurring needs across these perspectives into 29 operational requirements that cover the end-to-end lifecycle of a multi-institutional health AI study. The requirements fall into eight categories: (C1) consortium and study design; (C2) governance, ethics, and legal readiness; (C3) data readiness and interoperability; (C4) infrastructure and site onboarding; (C5) privacy and security engineering; (C6) federated protocol and execution control; (C7) validation, release, and reproducibility; and (C8) deployment, monitoring, and sustainability. Only C6 concerns distributed execution itself and the remaining seven categories describe the study-level work surrounding it. Table 1 defines each requirement and identifies representative supporting evidence.

2.2 Support concentrates on training, not the collaboration around it

We assessed 14 frameworks against the 29 requirements. Across the 406 framework–requirement pairs, mean normalized documented coverage was 32.6%, and no framework exceeded 51.7%. Coverage was highest for federated protocol and execution control (61.9%), followed by infrastructure and site onboarding (44.0%), privacy and security engineering (42.9%), and validation, release, and reproducibility (38.9%). It was lowest for the two categories that determine whether a study can begin: consortium and study design (9.5%) and governance, ethics, and legal readiness (11.9%). Data readiness and interoperability (22.0%) and deployment, monitoring, and sustainability (23.0%) were also weak (Figure 1).

Requirement-level results were sharper. Explicit and reproducible federated protocols were the best-supported requirement (R20, 76.2%), followed by secure communication and update confidentiality and execution observability, audit trail, and local approval (R18 and R23, both 61.9%). No framework documented an integrated process covering legal basis, ethics review, cross-site agreements, privacy-impact assessment, and jurisdiction mapping, leaving that column empty across all 14 frameworks (R04, 0%; Figure 1). Clinical purpose and FL suitability (R01) and common data specification and semantic interoperability (R08) each reached 4.8%, and risk-proportionate oversight and approval gates (R06) reached 7.1%. NVIDIA FLARE provided the broadest coverage (51.7%), followed by FedBioMed (48.3%), Flower (41.4%), and FATE (40.2%); their advantage arose from onboarding, security, orchestration, recovery, and observability functions rather than end-to-end study governance. **[The marginal bars in Figure 1 report 54.0, 51.7, 48.3, 48.3, 44.8 and 44.8 for the top six frameworks, and average to about 40.9% rather than 32.6%. The figure and this paragraph currently describe different scoring passes and must be reconciled before submission.]**

Two model families independently reproduced this pattern. Quadratic-weighted Cohen's κ against the expert assessment was 0.841 for Claude Opus 5 and 0.779 for GPT-5.6 Sol, with exact agreement on 79.8% and 68.0% of pairs and agreement within one ordinal level on 99.8% and 100% respectively. The families differed in absolute calibration, Claude Opus 5 scoring lower than GPT-5.6 Sol in 189 pairs and higher in 8, but their category-level rankings correlated at $\rho = 0.898$. Only 6 of 406 pairs showed a two-point spread across the three assessments, and the expert score fell at or between the two family scores in 401 pairs.

These values describe what each framework documents, not software quality, clinical effectiveness, security assurance, or regulatory compliance. Undocumented capabilities may exist in practice, and a documented feature may not be operationally mature. Documentation was chosen as the measure because it is what a prospective consortium can evaluate before committing to a platform.

The stable finding is a mismatch of layers. Frameworks are comparatively strong at configuring and executing distributed training, while the work that determines whether a collaboration can begin

and persist, including consortium formation, legal and ethics coordination, semantic alignment, release governance, and durable ownership, largely remains outside the runtime. Recent implementation and governance studies report the same boundary in practice.[22, 36, 37, 38, 41, 43] The result identifies a missing operational layer rather than a missing optimizer.

2.3 System design and operating boundaries

Fedlify occupies that layer. Because it operates in the categories where framework support is weakest, and because those categories are the ones nearest to institutional authority, the first design question is not what the system does but what it is separated from.

Figure 2a places Fedlify within the end-to-end workflow of a multi-institutional health AI study. The workflow spans three responsibility lanes. Institutions and their named approvers authorize the study objective, approve or stop the handoff, and decide on validation and release, while site engineers configure the approved runtime. Fedlify acts only in the second lane, during planning and preparation. Patient data and federated execution occupy the third lane and remain inside each participating institution. Two boundaries separate the lanes. Every crossing of the first is a signed human approval, and no query path or credential crosses the second. Fedlify holds no connection across either boundary, so the separation follows from the absence of any such connection rather than from an instruction to the model.

Starting from an institutionally authorized study objective, Fedlify structures requirements, requests approved site evidence, coordinates responsibilities, dependencies, and decisions, assesses documented readiness against defined conditions, and drafts a version-pinned handoff package (Figure 2b). Unresolved readiness gaps return the work to structuring rather than advancing it. Claims, evidence, decisions, and unresolved issues remain visible for institutional review throughout. The resulting package is inert. It reaches an established federated runtime only after a human approves it and site engineers inject credentials in a step that Fedlify never observes, and monitoring, incidents, retraining, or material changes reopen planning under the same gates.

Fedlify does not access patient data and does not execute federated training. It cannot establish a lawful basis for participation, grant ethics approval, validate site-level data, accept residual risk, or authorize clinical use. These responsibilities remain with the participating institutions.

2.4 Architecture: deterministic control above the model

The boundaries in Figure 2 describe what Fedlify is separated from. They do not by themselves explain what keeps the system on its own side of them, and that question matters because the failure modes reported for tool-using agents are precisely failures to respect a stated constraint.[50, 51, 52]

The central design choice is capability removal rather than instruction. A prompt telling a model not to open patient records is a probabilistic control competing with every other instruction in its context, including instructions embedded in retrieved documents. An architecture with no patient-data connector, no production credential, no network route, and no query interface removes that action from the set the model can reach. The same principle governs federated execution. Fedlify holds no runtime control channel, no model-write permission, and no deployment credential. Where a function would require patient-level data, a production secret, a live connection to a federation, or authority over a consequential decision, that function stays with an authorized person or an existing institutional system. This least-authority and per-request authorization posture draws on zero-trust architecture and secure-development guidance.[48, 49]

Figure 3 shows how this is realized as an authorization path. Deterministic software owns every transition, and the language model is called into that path rather than placed on it. A request first reaches an identity and intake gateway, which authenticates the user through institutional single sign-on, selects the tenant and project, classifies submitted files, and routes suspected patient data, credentials, active content, or injected instructions to quarantine before any model reads them. The policy engine then evaluates the request under deny-by-default rules and issues a signed work item fixing the task type, project and site scope, evidence set, output schema, allowed tools, data class, risk tier, budget, expiry, and policy version. This contract is the model's entire operating envelope, and the model cannot widen

it or declare the work complete.

Inside the band, a coordinator maps the request to the requirement set and plans work while holding no state, no tool access, and no approval authority. An ephemeral skill worker performs one bounded task against typed inputs, returns a structured draft, and is destroyed. Control returns to the deterministic verifier, which resolves source locators, matches hashes, and tests schema validity and requirement coverage. Only if those checks pass does a semantic verifier examine whether the resolved evidence supports the exact claim, whether artifacts contradict one another, and whether scope has drifted. Ordering the checks this way keeps model judgment away from questions that code can answer, and the verifier is read-only, so it can report a failure but not act on one. **[State whether the semantic verifier runs on a different model family from the drafting worker in the deployed system, and name it.]**

Six stores carry distinct write authorities. Models may propose facts, but only authorized users confirm them into the project fact ledger. The evidence vault is read-only to workers, the decision ledger is append-only, the artifact repository keeps immutable revisions, and the audit ledger is tamper-evident. Quarantined material sits outside model-readable storage entirely. This separation is what prevents conversation history, an untrusted retrieved document, or a draft assumption from becoming project truth. Provenance records bind approved artifacts to their sources, generating activities, responsible agents, and revisions,[58] so that when a source, skill, or parser is later found defective, dependent artifacts and approvals can be identified and their gates reopened.

Consequential transitions terminate at a named human gate, and export is one-way. A released package carries a signed manifest with no secret, no credential, no control channel, and no route back, and the receiving operator must perform an attested action before anything runs.

Each of these choices trades capability for containment, and Table 2 states the trade explicitly, naming for every principle the failure it addresses, the alternative rejected, the cost accepted, and where the principle is tested. **[Add one measured cost from the deployment, for example median added latency per work item or the observed escalation rate.]**

2.5 Governed work items and stopping rules

The architecture describes who may act. It does not yet describe what happens to a single unit of work over time, or how that work can fail to finish, which is where the separation between proposing and deciding becomes operational.

Work in Fedlify is not free-form conversation. Every unit of work is a work item instantiated from a skill contract, and both are deterministic artifacts the model reads but cannot author.

A skill contract is the governed template for one class of task. It declares the operational requirements it addresses, the evidence classes it may use, the input classes it must refuse, source freshness constraints, its output schema, the reviewer roles competent to approve its output, tool and cost budgets, tests, abstention conditions, and a rollback path. The initial taxonomy contains one contract pack per lifecycle category in Table 1. The correspondence is organizational rather than evidentiary, since defining a pack for a category does not establish that its requirements can be automated. Tasks resting on clinical interpretation, legal judgment, ethics review, local measurement, or risk acceptance terminate in a question, a draft, or an escalation addressed to a named role, and their contracts declare that outcome as normal rather than as failure.

Contracts also carry the limits of the standards they consume. HL7 FHIR and the OMOP Common Data Model supply pinned terminology and schema evidence, but a shared field name and unit do not establish that sampling route, acquisition timing, assay, or clinical meaning agree across sites.[56, 57] A contract using such evidence preserves these as separate claims with separate sources and owners rather than collapsing them into one asserted equivalence.

Instantiating a contract produces the signed work item described above, binding the task to a project and site scope, an evidence set, a risk tier, a budget, an expiry, and a policy version. The workflow engine then owns every subsequent transition (Figure 4). A request is checked for institutional authority and matched to an approved contract. Evidence is assembled and each element classified as a confirmed fact, an assumption, a proposal, a decision, a conflict, or unknown, and drafting runs only inside the scope that classification produces. Deterministic verification precedes semantic verification. No out-

put becomes approved because a model reports it complete, and the final transition requires a named reviewer holding a role the contract recognizes.

Rejection, revision, escalation, and expiry are first-class outcomes. The workflow stops and records a reason, a responsible owner, the affected dependencies, and the next permitted action when any of the following conditions is met:

1. the requested action has uncertain authority or falls outside the selected skill contract;
2. a required approval is absent, expired, out of scope, or bound to a different artifact version;
3. policies, agreements, laws, site records, or supplied evidence conflict in a way the system is not authorized to resolve;
4. an input or proposed output may contain patient-level data, credentials, active content, a model update, or another prohibited class;
5. evidence, ownership, or input completeness is insufficient for the requested claim or artifact;
6. deterministic or semantic verification identifies a critical unsupported claim, boundary violation, or unresolved contradiction;
7. the authorized tool, model, time, cost, or revision budget is exhausted.

In a stopped state Fedlify may summarize the issue and name the responsible role, but it may not infer approval, legal basis, risk acceptance, data quality, or a site attestation. Re-entry requires new authority or corrected evidence, so a work item cannot leave a stop by being redrafted more persuasively. **[Report what the deployment observed: work items executed, how many reached a human gate, how many stopped, and the count per condition. Conditions that never fired should be named and explained, since an unexercised stopping rule is untested rather than unnecessary.]**

The terminal contract in a study prepares the runtime configuration. A skill worker drafts it for the selected FL framework from the approved vendor-neutral protocol, the site responsibility map, and the recorded readiness attestations, and it passes the same path as any other output. Because its schema is the target runtime's job specification, deterministic verification checks it against that specification rather than against prose: site identifiers resolve to attested sites, images and library versions are pinned, declared resources fall within approved budgets, and credential fields hold named placeholders rather than values. Prohibited-content rules reject any embedded secret, private key, or outbound endpoint that would constitute a control channel. Semantic verification then asks whether the configuration expresses the protocol that was approved, since a configuration can be schema-valid and still encode a different study.

The result is a signed handoff package containing the study plan, data and protocol specifications, the drafted configuration, the responsibility map, evidence manifest, decisions, approvals, unresolved issues, and artifact hashes. The configuration is hash-bound to the protocol version it was generated from, so a later amendment marks it stale and reopens the affected gate. Fields the skill could not resolve are reported as unsupported, ambiguous, or semantically lossy rather than defaulted silently, and they reach the reviewer as open issues rather than as completed configuration.

The package is inert. Authoring a configuration and running one are separate capabilities, and Fedlify holds only the first. It has no runtime control channel, no deployment credential, and no route to a federation, so a drafted configuration cannot be applied from inside the system whatever an instruction, a retrieved document, or a generated artifact requests. A qualified engineer reviews the translation, supplies secrets through the institution's existing process, and controls execution. Fedlify records the handoff and any later attestations. It does not operate the federation. **[Name the runtimes with adapters and the share of the protocol each covers. Confirm that the four deterministic checks listed above match the implementation, and that staleness is tracked by hash binding rather than by another mechanism.]**

3 Discussion

The results do not show that FL frameworks are technically weak. They provide the strongest support for secure training and execution, and coverage decreases around it. Both model families and the expert assessment showed this pattern.

This distribution can be traced to the history of FL research. Researchers first formulated FL as a distributed optimization method for mobile devices.[18] They later adapted it to healthcare, where early work still focused mainly on technical concerns. Recent frameworks now support some tasks outside the training loop. NVIDIA FLARE, for example, defines project roles and provides tools for user administration, site administration, and project provisioning. These features explain why R05 and R03 received partial support in our assessment. FLOps offers a further example, providing a method for the efficient and continuous development of cross-silo FL systems. These developments extend framework support beyond model training. However, they still address mainly technical operations. Most frameworks in our sample were designed as general-purpose infrastructure for distributed training, not as tools for managing the sociotechnical demands of healthcare collaboration. The concentration of support in technical functions aligns with this design focus, but our assessment does not establish a causal relationship. **[Add references for the NVIDIA FLARE and FLOps claims.]**

Technical problems are not the only reason health AI projects fail. Clinical workflows, organizational structures, governance, and human factors determine whether a model reaches practice.[4, 41] Using a framework requires cross-site agreements, ethics and privacy approvals, shared data definitions, staff who can run it at each site, and a designated owner after the study ends. Reported barriers to collaboration concentrate in assembling these pieces rather than the training procedure. We therefore assessed the full lifecycle, not only the training loop.

Bounding the system creates a trade-off that should be stated plainly. Excluding patient-data access and runtime authority reduces the consequences of model error, prompt injection, and unsafe tool use, but it also limits what Fedlify can establish. The system cannot directly verify local data quality, subgroup fairness, privacy leakage, model performance, or runtime behaviour. It can structure the plans for those activities, identify missing or contradictory documentation, and retain disclosure-controlled reports or attestations produced by authorized local processes. The architecture therefore treats a stop, an escalation, or an unresolved issue as a valid output rather than as a failure to complete.

Several limitations apply. Documented support may understate capabilities that exist in practice but are absent from pinned public sources, and it may overstate operational readiness when a feature is documented but not independently tested. The model-family assessments shared a common evidence package and may share blind spots, so agreement is evidence of scoring convergence rather than of correctness. Human review remains an architectural control only to the extent that it is exercised, and nominal involvement does not by itself produce effective oversight.[60, 61] Forcing functions can reduce overreliance but may also reduce perceived usability and may not benefit all reviewers equally.[59] **[Implications for Fedlify and for practice.]**

4 Methods

4.1 Development of the operational requirement set

We characterized the operational work required across the lifecycle of a multi-institutional health AI study, from before training begins until after a model is released. Evidence was drawn from three lenses. The guidance lens covered systematic reviews, governance analyses, consensus statements, and implementation roadmaps.[22, 23, 36, 37] The practice lens covered procedures and barriers reported in real multi-institutional implementations.[9, 38, 41, 42] The capability lens covered operational functions described for healthcare-oriented platforms and current FL frameworks.[26, 39, 44, 45] Together the lenses represent what institutions are advised to prepare, what they encounter in practice, and what current software supports.

We extracted candidate needs from each lens, consolidated recurring concepts, and removed overlaps. A candidate was retained when it appeared in more than one lens and was explicitly discussed

in the source rather than inferred from it. Each retained requirement received an operational definition and representative supporting evidence, which produced the 29 requirements and eight categories in Table 1. The requirement set and its definitions were frozen before any framework was scored.

4.2 Framework selection and frozen evidence base

The comparison included TensorFlow Federated, FATE, FedML, Flower, NVIDIA FLARE, OpenFL, IBM Federated Learning, PaddleFL, Substra/SubstraFL, EasyFL, FLGo, Fedstellar, FedOps, and FedBioMed. The set represented research libraries, production-oriented runtimes, decentralized systems, and healthcare-oriented platforms. Inclusion required public code, sufficient technical documentation for requirement-specific assessment, and either a peer-reviewed publication or continued visibility in recent literature or practice.

The evidence cutoff was 5 July 2026 and was fixed before scoring began. For each framework, a registry recorded its identity, official repository, pinned commit, official documentation, primary scholarly source, and any prespecified additional source. Evidence was selected according to relevance to the requirement. Implementation code and configuration were inspected when overview documentation did not resolve a capability claim. Marketing statements, hypothetical custom extensions, and unsupported inference were not counted.

4.3 Ordinal scoring and evidence records

The unit of analysis was the framework–requirement pair. Each of the 406 pairs was scored on a four-level ordinal scale. A score of 0 indicated no documented support after a requirement-specific search, 1 limited or partial support or support dependent on a separate institutional process, 2 substantial but incomplete or configurable support, and 3 strong native end-to-end support. Scores of 0 and 1 therefore both indicate that the framework does not meet the requirement natively, and differ in whether any relevant documentation exists.

Every rating recorded a versioned source locator, an evidence paraphrase, a requirement-specific rationale, search notes, support mode, evidence strength, and confidence. For a score of 0, the search notes were required to identify the sources and terms examined, so that absence of support could be distinguished from absence of searching.

Three disambiguation rules applied throughout. Security functions were not treated as evidence of legal or ethics readiness, software project governance was distinguished from study governance, and simulation support was not treated as production deployment. Because the scale is ordinal, percentages indicate relative coverage rather than the proportion of a requirement met.

4.4 Expert assessment and reproducibility check

A human expert with experience in multi-institutional health AI research scored all 406 pairs against the frozen evidence package and scoring codebook. These scores constitute the primary assessment reported in Results.

To test whether the assessment could be reproduced independently, two model families, GPT-5.6 Sol and Claude Opus 5, each completed three isolated runs against the same frozen package, codebook, evidence registry, cutoff, prompt, and output schema, producing 1,218 ratings per family and 2,436 in total. Runs within a family shared no state. The family-level score for each pair was the median of its three runs. The expert was blinded to all model output, and the model runs were conducted without access to the expert scores. Reproducibility was assessed by comparing each family-level score with the expert score. Repeated runs within a family measure the stability of the scoring procedure and were not treated as independent evidence about a framework.

4.5 Coverage and agreement analysis

For any group of n framework–requirement pairs, normalized coverage was calculated as

$$\text{coverage} = 100 \times \frac{\sum_{i=1}^{n} s_i}{3n}, \qquad s_i \in \{0,1,2,3\}, \tag{1}$$

where $3n$ is the maximum attainable total for the group. Requirement-level coverage used $n = 14$, since each requirement was evaluated across 14 frameworks. Framework-level coverage used $n = 29$, since each framework was evaluated against 29 requirements. Category-level coverage used $n = 14m_c$ for a category containing m_c requirements.

Within-family stability across the three runs was summarized using ordinal Krippendorff's α, exact agreement across all three runs, agreement within one ordinal point, defined as a maximum–minimum difference of at most one, pairwise quadratic-weighted Cohen's κ, and pairwise mean absolute difference.[62, 63] Because Cohen's κ compares two raters, three pairwise estimates were obtained for each family.

Each family-level score was compared with the expert score using exact agreement, agreement within one point, mean absolute difference, quadratic-weighted κ, and Spearman rank correlation, at pair level and after averaging by framework, category, and requirement. The two model families were compared using the same measures as a secondary analysis. Binary threshold analyses at $s \geq 1$, representing any documented support, and $s \geq 2$, representing substantial or strong support, were treated as sensitivity analyses.

4.6 System design derivation and scope

Fedlify was derived through a traceable architecture-development process rather than through implementation optimization. Requirements with consistently weak framework coverage were mapped to candidate planning artifacts. Each candidate function was then subjected to a boundary test: any function requiring patient-level data, production credentials, a live FL control channel, or authority to make an institutional decision was excluded or assigned to an external role. The retained functions were decomposed into deterministic control tasks, bounded model-mediated drafting tasks, and human decisions. A threat-model pass assigned each failure class to a control and named the residual owner, drawing on zero-trust and secure-development guidance, agent-security studies, and current AI risk-management and health-AI governance guidance.[48, 49, 50, 51, 52, 53, 54, 55, 40] Workflow states, stopping conditions, record types, provenance relations, and change-invalidation rules were then specified.

[Implementation and experimental setup remain to be written. At minimum this section needs the stack and deployment shape, the model providers and configurations used, the runtimes for which adapters exist, and the protocol for the adversarial and demonstration studies promised in the Introduction.]

Table 1: Evidence-informed operational requirements for end-to-end multi-institutional health AI studies.

ID	Requirement	Operational definition and representative evidence
1. Consortium and study design		
R01	Clinical purpose and FL suitability	Define the intended clinical or research use, target population, decision context, expected collaborative benefit, and why FL is preferable to feasible alternatives before selecting a platform.[23, 36, 37, 38, 39, 40]
R02	Consortium, site-readiness, and contribution planning	Select sites that can contribute clinically relevant data and sustained local capability, and assess each site's data, infrastructure, staff, constraints, incentives, and expected contribution.[9, 22, 37, 38, 41, 42, 43]
R03	Multidisciplinary roles, coordination, and shared vocabulary	Create a working structure that connects clinical, data-science, engineering, IT, security, privacy, ethics, legal, project-management, and patient or public perspectives across institutions.[22, 26, 37, 38, 41, 43]
2. Governance, ethics, and legal readiness		

Table 1 continued

ID	Requirement	Operational definition and representative evidence
R04	Legal basis, ethics, and cross-site agreements	Establish the lawful and ethical basis for local data use, distributed computation, exchange of model artifacts, and cross-institutional collaboration in every participating jurisdiction.[22, 37, 38, 39, 41]
R05	Accountability, ownership, and decision rights	Specify who owns or controls data, code, configurations, models, logs, and outputs, and who may approve, pause, release, modify, or retire them.[22, 26, 37, 38, 39, 41, 43]
R06	Risk-proportionate oversight and approval gates	Match governance, privacy, security, validation, and release review to the sensitivity of the data, model capability, intended use, and potential clinical impact.[22, 37, 38, 39, 40]
R07	Participation lifecycle, synchronized change control, and withdrawal	Define how sites join, approve tasks, request changes, pause, leave, or are removed while preserving safety, reproducibility, and consortium continuity.[22, 37, 38, 41, 43]
3. Data readiness and interoperability		
R08	Common data specification and semantic interoperability	Create a shared, machine-actionable definition of variables, labels, units, coding systems, metadata, and allowable mappings across sites.[22, 26, 36, 37, 38, 44, 45, 46]
R09	Harmonized preprocessing, acquisition, and annotation	Ensure that local extraction, cohort construction, preprocessing, missing-data handling, acquisition, and labeling follow agreed protocols, or that deviations are measured and documented.[9, 22, 26, 36, 37, 38]
R10	Data quality and training-readiness validation	Run local checks to establish whether each site's data, metadata, labels, and references are complete, valid, correctly linked, and processable before federated execution.[9, 26, 36, 37, 38]
R11	Representativeness, heterogeneity, and partition plan	Characterize clinical, demographic, temporal, acquisition, label, and site-level differences and design train, validation, test, and external-evaluation partitions accordingly.[9, 36, 37, 38, 40]
4. Infrastructure and site onboarding		
R12	Compute, storage, network, and availability readiness	Verify that each site and coordinating service can meet agreed compute, storage, bandwidth, firewall, uptime, maintenance, and support requirements without disrupting clinical operations.[26, 36, 37, 38, 41, 42]
R13	Reproducible runtime and cross-site version compatibility	Standardize and version operating systems, libraries, drivers, containers or virtual environments, configurations, and update procedures so the same task executes consistently at every node.[26, 36, 37, 38, 44, 45]
R14	Clinical-system integration and secure local data access	Connect each FL node to approved local sources and third-party systems through least-privilege interfaces while preventing raw patient data from leaving the institution.[26, 36, 37, 38, 44, 45, 46]
R15	Site onboarding, dry-run, and readiness gates	Use repeatable onboarding and non-sensitive or synthetic dry-runs to confirm connectivity, configuration, security, workflow, observability, and staffing before real training begins.[26, 37, 38, 39, 42, 44]
5. Privacy and security engineering		
R16	Threat model and risk-tiered privacy and security controls	Identify credible threats to data, model updates, code, nodes, the aggregator, users, and outputs, then select controls in proportion to likelihood, impact, and intended use.[22, 26, 36, 37, 39]

Table 1 continued

ID	Requirement	Operational definition and representative evidence
R17	Identity, authentication, authorization, and secrets management	Ensure that people, services, and sites are authenticated and receive only the permissions required for their approved roles, with controlled credential and key lifecycles.[22, 26, 37, 39, 44]
R18	Secure communication and update confidentiality	Protect model artifacts and control traffic in transit and, where justified, during aggregation, while specifying what information crosses institutional boundaries.[22, 26, 36, 37, 39, 44]
R19	Code, model, and update integrity with incident response	Prevent, detect, contain, and recover from malicious or erroneous code, poisoned updates, compromised nodes, unauthorized changes, and security or privacy incidents.[22, 26, 36, 37, 38, 39]
6. Federated protocol and execution control		
R20	Explicit and reproducible federated protocol	Specify the complete study protocol so another authorized team can reproduce how clients, server, data processing, training, validation, and stopping decisions interact.[26, 36, 37, 38, 43, 44, 47]
R21	Resource-aware orchestration and heterogeneity handling	Schedule and coordinate jobs around unequal data distributions, hardware, bandwidth, uptime, time zones, and clinical workloads without allowing resource-rich sites to dominate silently.[26, 36, 37, 38, 41, 42, 47]
R22	Fault tolerance, checkpointing, and recoverability	Continue safely or recover predictably when clients disconnect, nodes fail, configurations mismatch, jobs crash, or maintenance interrupts training.[26, 36, 37, 38, 42]
R23	Execution observability, audit trail, and local approval	Give authorized central and local actors enough visibility to understand, approve, monitor, diagnose, and audit each job without exposing patient-level data.[22, 26, 36, 37, 38, 39, 42, 44, 43]
7. Validation, release, and reproducibility		
R24	Multidimensional local, external, and subgroup evaluation	Evaluate more than global accuracy by measuring site-level and external performance, calibration, robustness, subgroup fairness, privacy and security, communication, resource use, and scalability against relevant alternatives.[9, 36, 37, 38, 39, 40, 47]
R25	Independent validation and controlled release gate	Require independent or site-local validation and multidisciplinary approval before a final model, code package, or result is distributed, deployed, or used for a new purpose.[9, 22, 37, 38, 39, 40]
R26	Reproducibility, reporting, provenance, and registry package	Package the information and artifacts needed to understand, reproduce, audit, compare, and govern the study and every released model version without revealing protected data.[22, 26, 36, 37, 39, 40, 43, 44, 45]
8. Deployment, monitoring, and sustainability		
R27	Workflow integration, usability, and stakeholder capability	Fit the model and operational process into clinical or research workflows and ensure users, data stewards, IT teams, and oversight actors can perform and understand their responsibilities.[22, 37, 40, 41, 44]
R28	Continuous performance, drift, fairness, security, and compliance monitoring	Monitor the deployed or reused system and its federation for degradation, distribution shift, subgroup harm, misuse, access violations, security events, and regulatory or contextual change.[22, 36, 37, 38, 39, 40]

Table 1 continued

ID	Requirement	Operational definition and representative evidence
R29	Update, retraining, rollback, retirement, and sustainability ownership	Assign durable organizational and financial ownership for maintenance, updates, retraining, rollback, incident recovery, site withdrawal, transfer, and retirement after the initial study or funding period.[22, 37, 38, 40, 41]

Table 2: Fedlify design principles, the failure each addresses, the alternative rejected, the cost accepted, and where the principle is tested.

Principle	Failure it addresses	Alternative rejected	Cost accepted	Where tested
P1 Capability removal over instruction	A consequential action stays reachable through a prompt, a retrieved document, or a model update.[50, 51, 52] Least-authority provisioning follows zero-trust and secure-development guidance.[48, 49]	A broadly capable agent constrained by system prompts and refusal behaviour	Functions needing an excluded capability stay permanently outside Fedlify and fall to a person or an existing system	Tier 2 adversarial suite
P2 Deterministic software above the model	The model deciding what it is permitted to do, or which workflow state is authoritative	Model-mediated policy interpretation and state control	Policies must be expressible as code, so nuanced cases stop or escalate rather than resolve	Tier 1 policy and state-transition conformance
P3 Evidence before assertion	A fluent, unsupported claim entering a reviewed or approved artifact. Traceability of claims to sources is a standing requirement of health-AI reporting guidance.[40]	Drafting first and attaching citations after the claim is written	Source curation, locator resolution, and freshness checking become recurring operational costs	Tier 1 verifier coverage; Tier 3 source inspection
P4 Typed memory with human confirmation	A draft assumption or a hostile source silently becoming a project fact. Provenance binds artifacts to sources, activities, and responsible agents.[58]	Treating conversation history as accumulated project state	Authorized users must confirm structured records and resolve conflicts before work proceeds	Tier 1 store write-rule tests; Tier 2 poisoned evidence
P5 Verification split by kind	Machine-resolvable failures hidden inside model judgment, or model agreement reported as proof	One undifferentiated model-based critic reporting a single combined pass rate	Two verification paths must be built, tested, and reported separately, and their correlation measured rather than assumed	Tier 1, Tier 2, and the drafting–verification correlation analysis
P6 Human authority bound to exact artifacts	Approval by accumulation, in which no accountable person decides on the released version. Nominal involvement does not by itself produce effective oversight.[60, 61, 59]	Agent-proposed approval followed by routine human sign-off	Multi-site review stays on the critical path, and a material change reopens the affected gate	Tier 3 human-factors evaluation
P7 Non-self-executing handoff	Generated runtime configuration silently becoming a running system	Direct configuration push from the planning layer to an FL runtime	A qualified engineer must review and act on every handoff package, adding a scheduled step	Tier 1 export validation; Tier 2 approval spoofing
P8 Model-agnostic controls	Safety properties disappearing after a provider or model change. Risk-management guidance treats provider substitution as a lifecycle event.[53, 54]	Reliance on one provider's model-specific safety tooling	Provider abstraction and comparative testing add engineering work	Cross-provider regression suite

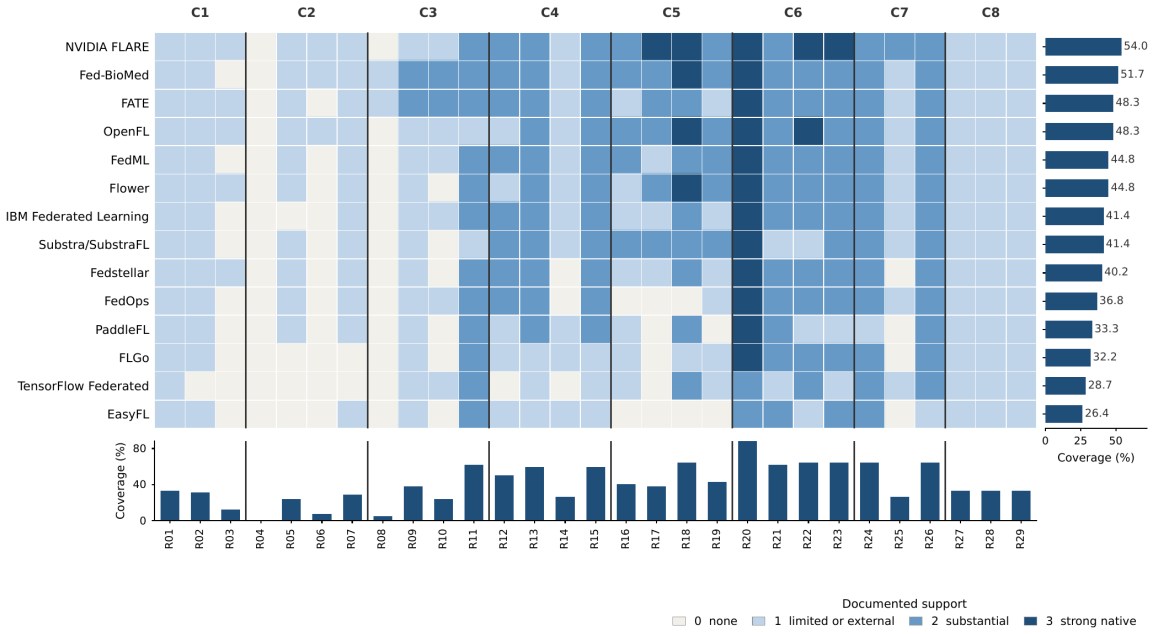


Figure 1: Documented capability coverage across the operational lifecycle. Each cell is one framework–requirement pair, scored 0 to 3 against the frozen evidence package. Rows are ordered by total coverage and columns are grouped by lifecycle category (C1 to C8). Marginal bars give normalized coverage per framework (right) and per requirement (below). Coverage concentrates in federated protocol and execution control (C6) and thins toward the categories governing how a study begins (C1, C2) and how it is sustained (C8). Values are the expert assessment.

Figure 1: Documented capability coverage across the operational lifecycle. Each cell is one framework–requirement pair, scored 0 to 3 against the frozen evidence package. Rows are ordered by total coverage and columns are grouped by lifecycle category (C1 to C8). Marginal bars give normalized coverage per framework (right) and per requirement (below). Coverage concentrates in federated protocol and execution control (C6) and thins toward the categories governing how a study begins (C1, C2) and how it is sustained (C8).

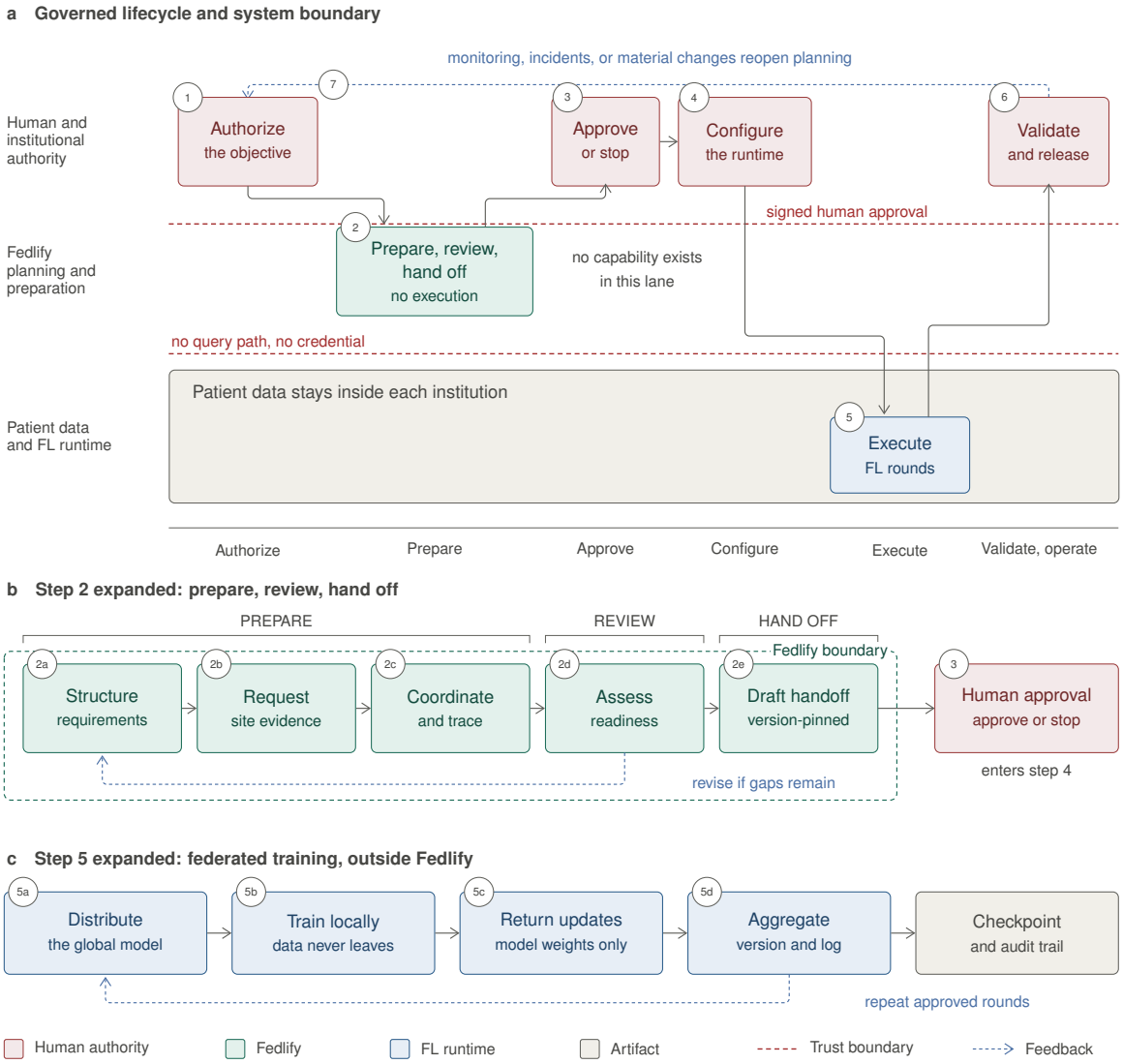


Figure 2: Fedlify within the multi-institutional health AI lifecycle. a, A six-step process is distributed across three responsibility lanes, with authority transferring at two boundaries. Institutions authorize the objective and approve the handoff, Fedlify supports planning and preparation, site engineers configure the approved runtime, and the FL runtime executes training before institutional validation, release, and operation. Monitoring, incidents, retraining, or material changes reopen planning. **b**, Step 2 expanded. Fedlify structures requirements, requests approved site evidence, coordinates responsibilities and decisions, assesses readiness, and drafts a version-pinned handoff. Human approval sits outside the Fedlify boundary. **c**, Step 5 expanded. Federated training runs on an established runtime that Fedlify cannot start, stop, observe, or receive from. Raw patient records never leave the institution.

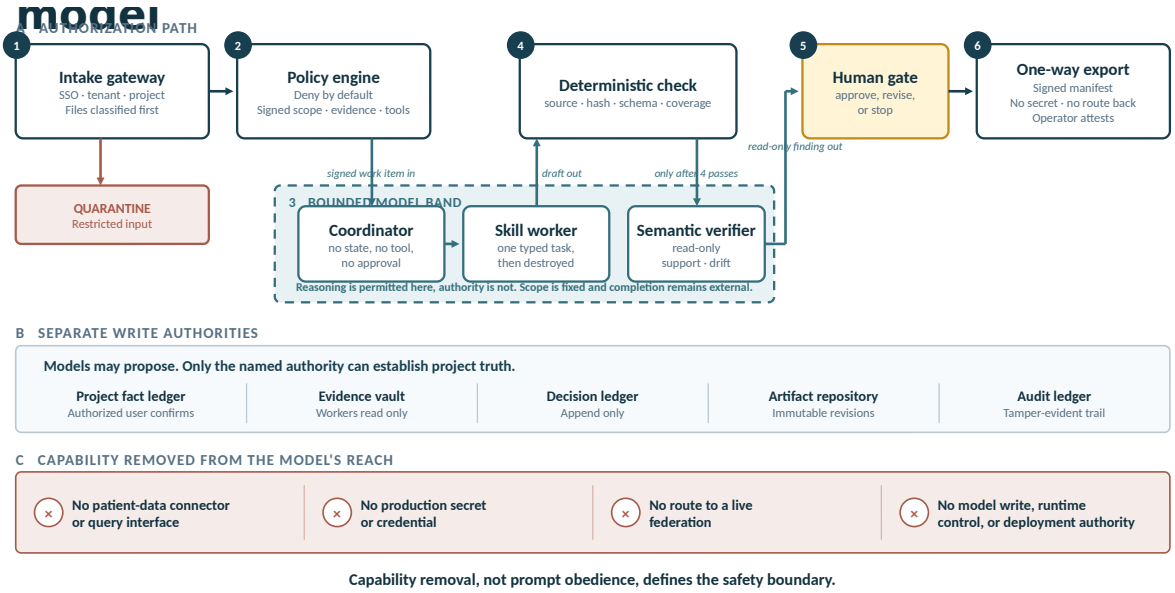


Figure 3: Deterministic control above the model. **A**, The authorization path. Deterministic services own every transition; the path enters the bounded model band twice and returns to deterministic control each time, carrying a signed work item inward and a draft or a read-only finding outward. The semantic verifier is a model and therefore sits inside the band, read-only, running only after the deterministic check passes. **B**, Stores with separate write authorities. Models may propose; only a named authority establishes project truth. **C**, Capabilities absent from the deployment, which is what makes the boundary a property of the architecture rather than of an instruction.

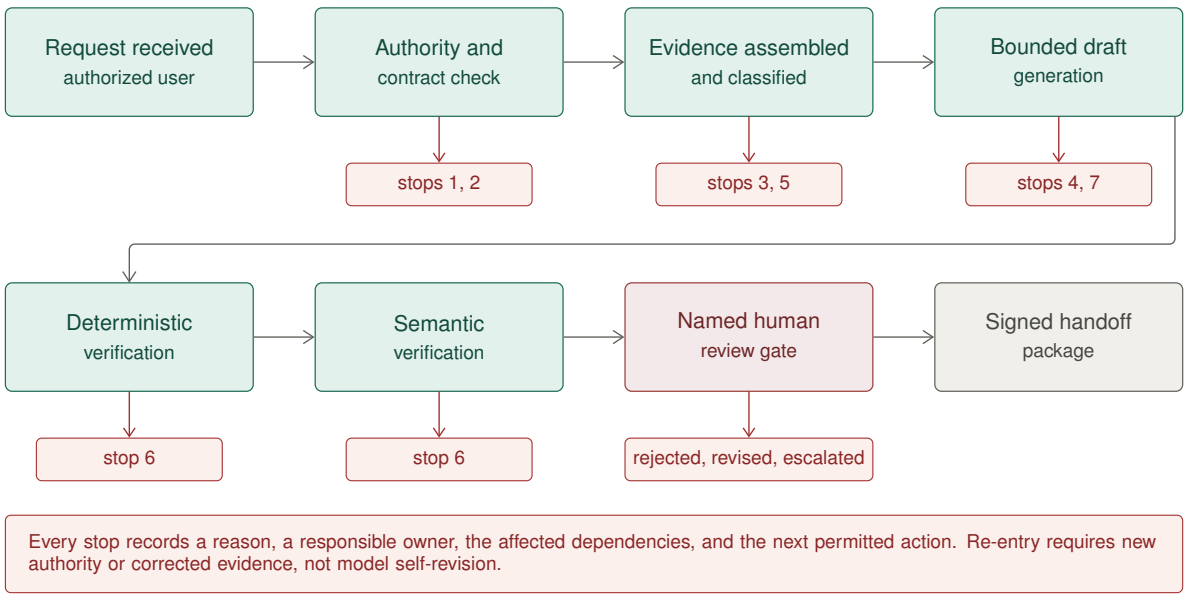


Figure 4: Governed work-item lifecycle and stopping rules. The workflow engine, not the model, owns every state transition. Stopping conditions 1 to 7 are attached to the states at which they fire. Failed authorization, incomplete or conflicting evidence, prohibited content, verification failure, human rejection, expiry, or exhausted budgets all lead to a recorded stop rather than to a forced completion.

References

[1] Balch, J., Upchurch, G. R., Bihorac, A. & Loftus, T. J. Bridging the artificial intelligence valley of death in surgical decision-making. *Surgery* **169**, 746–748 (2021).

[2] Gallifant, J. *et al.* Beyond the algorithm: a field guide to deploying AI agents in clinical practice (2025).

[3] Eapen, B. R. & Singh, N. Navigating the "valley of death": an open-source, modular framework for generative AI in healthcare. In *Opening the Personal Gate between Technology and Health Care*, 1561–1562 (IOS Press, 2026).

[4] Salwei, M. E. & Carayon, P. A sociotechnical systems framework for the application of artificial intelligence in health care delivery. *J. Cogn. Eng. Decis. Mak.* **16**, 194–206 (2022).

[5] Sokol, K., Fackler, J. & Vogt, J. E. Artificial intelligence should genuinely support clinical reasoning and decision making to bridge the translational gap. *npj Digit. Med.* **8**, 345 (2025).

[6] Yang, J. *et al.* Generalizability assessment of AI models across hospitals in a low-middle and high income country. *Nat. Commun.* **15**, 8270 (2024).

[7] Ong Ly, C. *et al.* Shortcut learning in medical AI hinders generalization. *npj Digit. Med.* **7**, 124 (2024).

[8] Ktena, I. *et al.* Generative models improve fairness of medical classifiers under distribution shifts. *Nat. Med.* **30**, 1166–1173 (2024).

[9] Pati, S. *et al.* Federated learning enables big data for rare cancer boundary detection. *Nat. Commun.* **13**, 7346 (2022).

[10] Dayan, I. *et al.* Federated learning for predicting clinical outcomes in patients with COVID-19. *Nat. Med.* **27**, 1735–1743 (2021).

[11] Lee, E. H. *et al.* An international study presenting a federated learning AI platform for pediatric brain tumors. *Nat. Commun.* **15**, 7615 (2024).

[12] Alami, H. *et al.* Understanding the integration of artificial intelligence in healthcare organisations and systems through the NASSS framework. *BMC Health Serv. Res.* **24**, 701 (2024).

[13] Hassan, M., Kushniruk, A. & Borycki, E. Barriers to and facilitators of artificial intelligence adoption in health care: scoping review. *JMIR Hum. Factors* **11**, e48633 (2024).

[14] Suleman, M. U. *et al.* Assessing the generalizability of artificial intelligence in radiology. *Ann. Med. Surg.* **87**, 8803–8811 (2025).

[15] Arun, S. *et al.* Systematic scoping review of external validation studies of AI pathology models for lung cancer diagnosis. *npj Precis. Oncol.* **9**, 166 (2025).

[16] Pandian, B. *et al.* Generalizing machine learning models from clinical free text. *Sci. Rep.* **15**, 31668 (2025).

[17] Naderian, S. *et al.* A systematic review of artificial intelligence-based clinical decision support systems in prostate cancer management. *Healthc. Technol. Lett.* **12**, e70026 (2025).

[18] McMahan, B., Moore, E., Ramage, D., Hampson, S. & Agüera y Arcas, B. Communication-efficient learning of deep networks from decentralized data. In *AISTATS*, 1273–1282 (2017).

[19] ur Rehman, M. H. & Gaber, M. M. *Federated Learning Systems: Towards Next-Generation AI*, vol. 965 (Springer Nature, 2021).

[20] Welten, S. *et al.* A study on interoperability between two personal health train infrastructures in leukodystrophy data analysis. *Sci. Data* **11**, 663 (2024).

[21] Barbereau, T., Fernandez, J. D. & Menci, S. P. The governance of federated learning: a decision framework for organisational archetypes. *Data Policy* **7**, e53 (2025).

[22] Eden, R. *et al.* A scoping review of the governance of federated learning in healthcare. *npj Digit. Med.* **8**, 427 (2025).

[23] Teo, Z. L. *et al.* Federated machine learning in healthcare: a systematic review on clinical applications and technical architecture. *Cell Rep. Med.* **5** (2024).

[24] Jafarinezhad, O. *et al.* Centralized pooling and federated learning for Canadian patient-level data sharing in multicenter medical AI: a scoping review. *Artif. Intell. Med.* 103422 (2026).

[25] Matschinske, J. *et al.* The FeatureCloud platform for federated learning in biomedicine. *J. Med. Internet Res.* **25**, e42621 (2023).

[26] Cremonesi, F. *et al.* Fed-BioMed: open, transparent and trusted federated learning for real-world healthcare applications. In *Federated Learning Systems*, 19–41 (Springer, 2025).

[27] Schneider, J. Generative to agentic AI: survey, conceptualization, and challenges. *arXiv:2504.18875* (2025).

[28] Bandi, A., Kongari, B., Naguru, R., Pasnoor, S. & Vilipala, S. V. The rise of agentic AI. *Future Internet* **17**, 404 (2025).

[29] Zhao, W. *et al.* An agentic system for rare disease diagnosis with traceable reasoning. *Nature* **651**, 775–784 (2026).

[30] Goh, H. L. *et al.* Personalised health plan development using agentic AI in Singapore's national preventive care programme. *npj Digit. Med.* **9**, 332 (2026).

[31] Li, H., Funk, M. & Saeed, A. Helmsman: autonomous synthesis of federated learning systems via collaborative LLM agents. *arXiv:2510.14512* (2025).

[32] Ji, H. *et al.* LAFA: agentic LLM-driven federated analytics over decentralized data sources. In *IEEE CloudCom*, 1–8 (2025).

[33] Isong, J. A., Kanu, V. I., Ajakwe, S. O. & Kim, D.-S. Federated agentic learning with adaptive privacy for cardiovascular anomaly detection at the edge. In *ICTC*, 152–157 (IEEE, 2025).

[34] OpenAI. OpenAI and Hugging Face partner to address security incident during model evaluation (2026). Published 21 July 2026, accessed 25 July 2026.

[35] Ashraf, T., Jeong, H., Thoker, F. M. & Ghanem, B. MedCTA: a benchmark for clinical tool agents. *arXiv:2606.11702* (2026).

[36] Li, M., Xu, P., Hu, J., Tang, Z. & Yang, G. From challenges and pitfalls to recommendations and opportunities: implementing federated learning in healthcare. *Med. Image Anal.* **101**, 103497 (2025).

[37] Kommusaar, J. *et al.* A roadmap for federated learning projects using health data to guide sustainable artificial intelligence development in the European Union. *Int. J. Med. Inform.* 106242 (2025).

[38] Bujotzek, M. R. *et al.* Real-world federated learning in radiology: hurdles to overcome and benefits to gain. *J. Am. Med. Inform. Assoc.* **32**, 193–205 (2025).

[39] Bottomly, D. *et al.* A pragmatic framework for federated learning risk and governance in academic medical centers. *JMIR AI* **5**, e80022 (2026).

[40] Lekadir, K., Frangi, A. F., Porras, A. R. *et al.* FUTURE-AI: international consensus guideline for trustworthy and deployable artificial intelligence in healthcare. *BMJ* **388**, e081554 (2025).

[41] Peltonen, L.-M. & Chomutare, T. Federated learning's uncomfortable truth: why human networks matter more than neural networks. *J. Am. Med. Inform. Assoc.* ocag047 (2026).

[42] Schoenpflug, L. A. *et al.* Navigating real-world challenges: a case study on federated learning in computational pathology. *J. Pathol. Inform.* 100464 (2025).

[43] Schlegel, M., Scheliga, D., Sattler, K.-U., Seeland, M. & Mäder, P. Lowering barriers to federated learning: collaboration management and provenance. *J. Big Data* **13**, 28 (2026).

[44] Mullie, L. *et al.* CODA: an open-source platform for federated analysis and machine learning on distributed healthcare data. *J. Am. Med. Inform. Assoc.* **31**, 651–665 (2024).

[45] Chavero-Diez, M., Hernandez-Ferrer, C., Codó, L., Gelpí, J. L. & Capella-Gutiérrez, S. Federated learning frameworks: quality and interoperability for biomedical research. *NAR Genom. Bioinform.* **8**, lqag010 (2026).

[46] Lee, G. H. *et al.* Feasibility study of federated learning on the distributed research network of OMOP common data model. *Healthc. Inform. Res.* **29**, 168–173 (2023).

[47] Chai, D. *et al.* A survey for federated learning evaluations: goals and measures. *IEEE Trans. Knowl. Data Eng.* **36**, 5007–5024 (2024).

[48] Rose, S., Borchert, O., Mitchell, S. & Connelly, S. Zero trust architecture. NIST Special Publication 800-207 (2020).

[49] Booth, H. *et al.* Secure software development practices for generative AI and dual-use foundation models. NIST Special Publication 800-218A (2024).

[50] Greshake, K. *et al.* Not what you have signed up for: compromising real-world LLM-integrated applications with indirect prompt injection. In *ACM AISec*, 79–90 (2023).

[51] Ruan, Y. *et al.* Identifying the risks of LM agents with an LM-emulated sandbox. In *ICLR* (2024).

[52] Debenedetti, E. *et al.* AgentDojo: a dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *NeurIPS Datasets and Benchmarks* (2024).

[53] Tabassi, E. Artificial intelligence risk management framework (AI RMF 1.0). NIST AI 100-1 (2023).

[54] Autio, C., Schwartz, R., Dunietz, J. *et al.* Artificial intelligence risk management framework: generative artificial intelligence profile. NIST AI 600-1 (2024).

[55] World Health Organization. *Ethics and Governance of Artificial Intelligence for Health: Guidance on Large Multi-Modal Models* (WHO, Geneva, 2025).

[56] Health Level Seven International. HL7 FHIR release 4, version 4.0.1 (2019).

[57] Observational Health Data Sciences and Informatics. OMOP common data model, version 5.4 (2022).

[58] Lebo, T., Sahoo, S., McGuinness, D. *et al.* PROV-O: the PROV ontology. W3C Recommendation (2013).

[59] Buçinca, Z., Malaya, M. B. & Gajos, K. Z. To trust or to think: cognitive forcing functions can reduce overreliance on AI in AI-assisted decision-making. *Proc. ACM Hum.-Comput. Interact.* **5**, 1–21 (2021).

[60] Parasuraman, R., Sheridan, T. B. & Wickens, C. D. A model for types and levels of human interaction with automation. *IEEE Trans. Syst. Man Cybern. A* **30**, 286–297 (2000).

[61] Amershi, S., Weld, D., Vorvoreanu, M. *et al.* Guidelines for human–AI interaction. In *CHI*, 1–13 (2019).

[62] Hayes, A. F. & Krippendorff, K. Answering the call for a standard reliability measure for coding data. *Commun. Methods Meas.* **1**, 77–89 (2007).

[63] Cohen, J. Weighted kappa: nominal scale agreement with provision for scaled disagreement or partial credit. *Psychol. Bull.* **70**, 213–220 (1968).